PROJECT-WORK · CORSO AI/CV

Valerio Querzoli · Unimore

Un IDS *ibrido* per il traffico di rete

Classificazione supervisionata + autoencoder

IL PROBLEMA

Un classificatore riconosce solo gli attacchi che ha già visto.

OBIETTIVI

1. **Riconoscere gli attacchi noti**
2. **Segnalare quelli mai visti (zero-day)**
3. **Misurare onestamente quanto aiuta il secondo livello**

Valerio Querzoli · Unimore

Dati: CIC-IDS2017 e *pulizia*

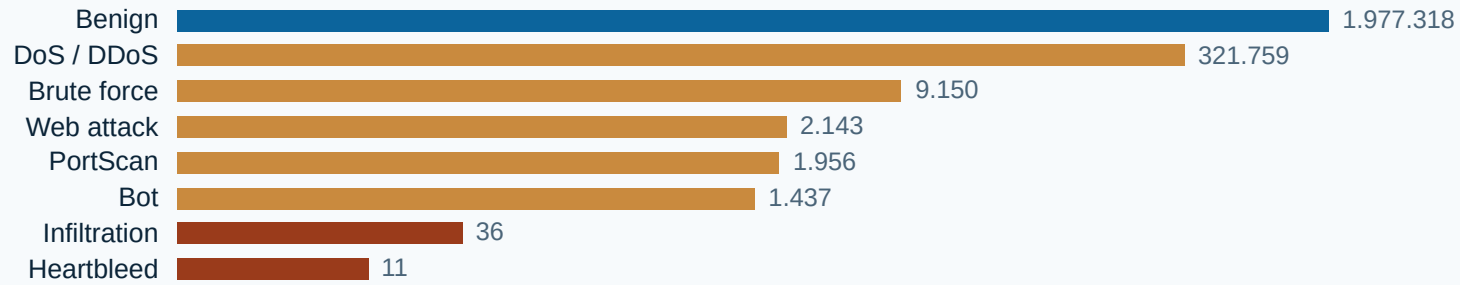
PACCHETTI

UN FLUSSO = UNA RIGA DI NUMERI

CICFlowMeter →

durata | byte → | byte ← | tempo tra pacchetti | flag SYN | … | etichetta

FLUSSI PER FAMIGLIA, PRIMA DELLA PULIZIA · LUNGHEZZA IN SCALA LOG



DATASET

2,3 milioni

flussi, rete di laboratorio

PULIZIA

2.843

righe rimosse · 2.143 etichette corrette

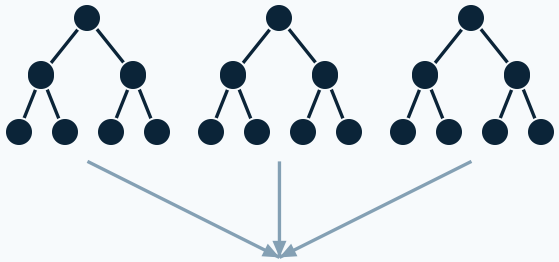
SPLIT CASUALE 60 / 20 / 20

1.386.580

train · 462.193 val · 462.194 test

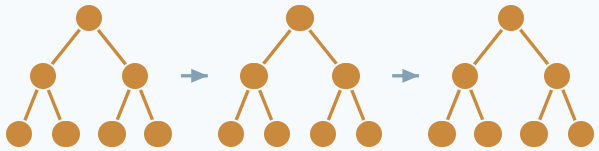
Valerio Querzoli · Unimore

Tre modelli, due modi di *imparare*



Random Forest

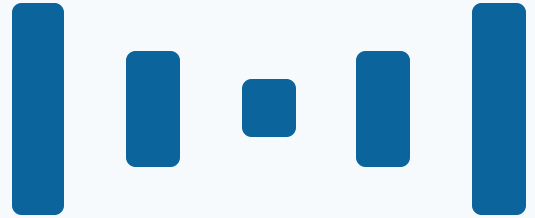
Molti alberi di decisione indipendenti: ognuno vota, vince la maggioranza. Usato come baseline.



+ correzione + correzione

XGBoost

Alberi in sequenza: ognuno corregge gli errori del precedente.



× 2: feature grezze e in scala log

Autoencoder

Due reti neurali che comprimono e ricostruiscono il traffico normale: errore alto = anomalo.

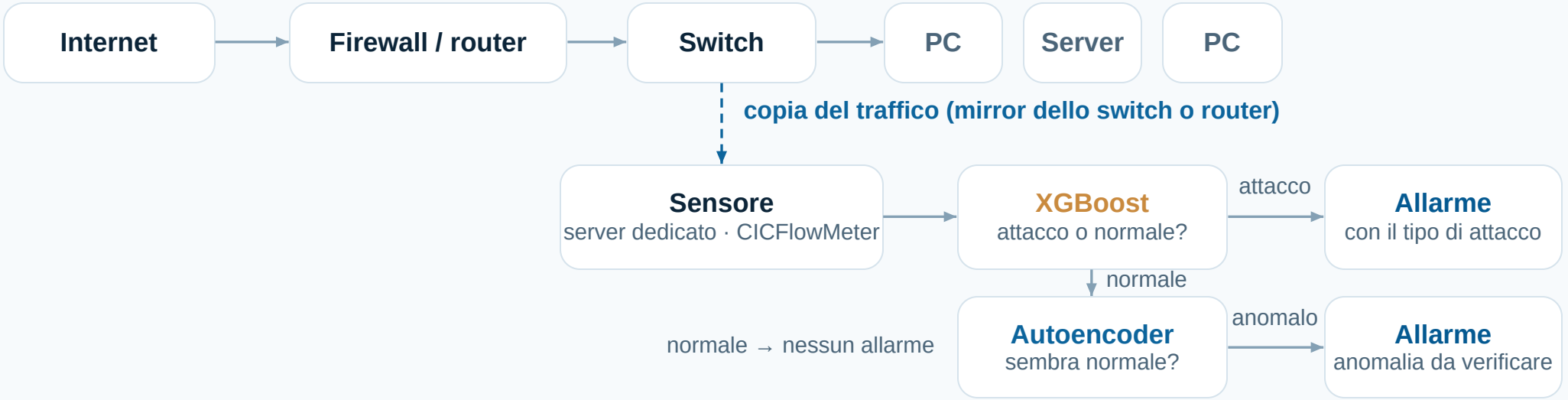
RF e XGBoost imparano gli attacchi. L'autoencoder impara solo il traffico normale.

Ensemble: errori complementari; punteggio = media dei due, ciascuno diviso per il suo 99° percentile (Benign)

Valerio Querzoli · Unimore

XGBoost + autoencoder, *in cascata*

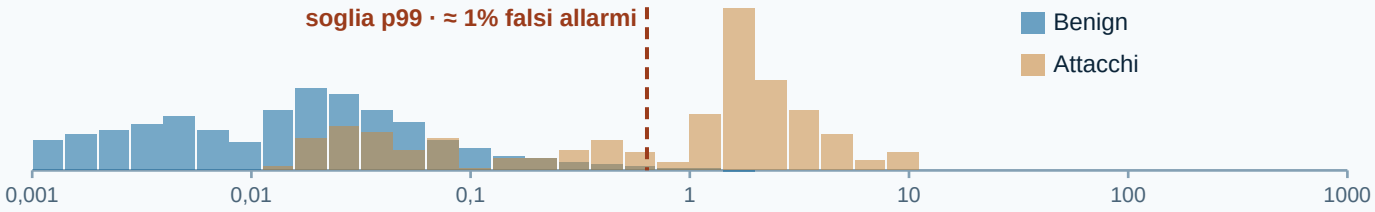
DOVE SI COLLOCA



NEL PROGETTO

Analisi offline di flussi registrati: CIC-IDS2017. Non in tempo reale.

ERRORE DI RICOSTRUZIONE (VALIDATION, UN AUTOENCODER)



Valerio Querzoli · Unimore

Come ho testato, e cosa è *emerso*

IL TEST

Escludo un'intera famiglia di attacchi dal training, poi la cerco nel test set.

FAMIGLIA DOS · 64.317 CASI (TEST)

18,1% → 74,7%

XGBoost solo → + AE · 5 seed: 74,1 ± 0,5%

≈ +1% falsi allarmi

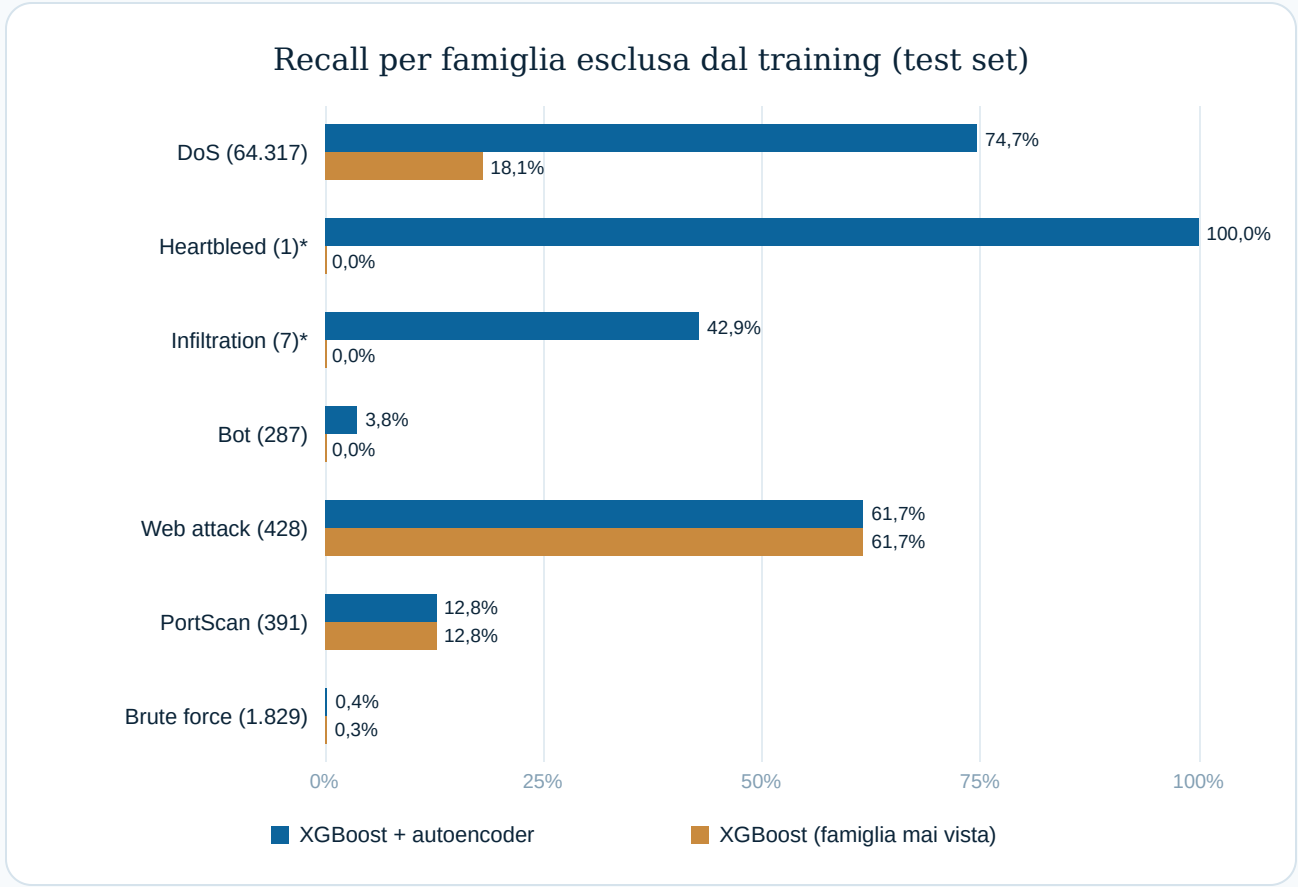
3.944 su 394.934 flussi normali

CONTROLLO IN-DOMINIO (TEST)

97,9% → 98,4%

l'autoencoder serve solo per lo zero-day

* 1 e 7 casi: non sono stime. Split casuale: i numeri in-dominio sono ottimistici.



Valerio Querzoli · Unimore

Pro e *contro*

Pro

- Recupera zero-day volumetrici
- Autoencoder leggero e veloce
- Soglia regolabile sui falsi allarmi

Contro

- Circa +1% di falsi allarmi
- AE non aiuta su scan, brute force, bot
- Va allenato per ogni rete

SOGLIA REGOLABILE · TEST SET, MEDIA DI 5 SEED





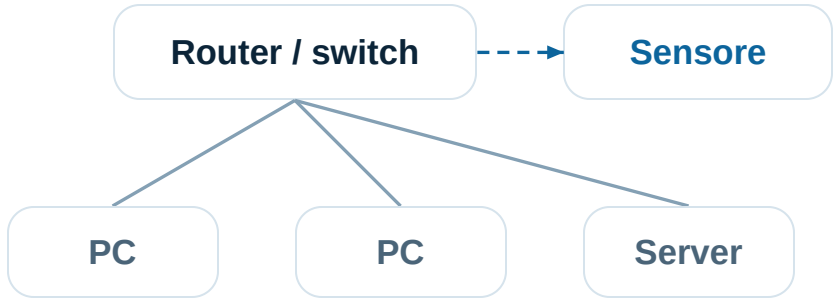
DIFFICOLTÀ INCONTRATE

Bug nel dataset | **Bug di CICFlowMeter** | **Classi sbilanciate**

Valerio Querzoli · Unimore

IDS di rete e EDR: due *punti di vista*

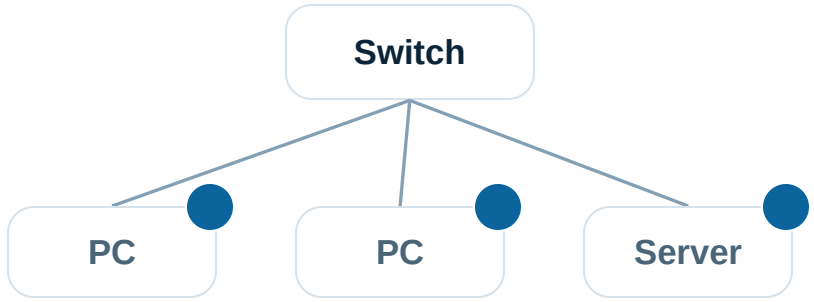
IDS di rete · questo progetto



Vede: tempi, dimensioni, flag TCP

Non vede: il contenuto dei pacchetti (payload)

EDR · un agente su ogni host



Vede: processi, utenti, payload decifrato

CrowdStrike · SentinelOne · Defender

Valerio Querzoli · Unimore

Zero-day, limiti e *conclusione*

COME VIENE VISTO UNO ZERO-DAY

Reso visibile, non risolto
Diventa un allarme da verificare, non una classificazione certa.

Anomalia, non attacco
Anche traffico legittimo mai visto fa scattare l'allarme.

LIMITI

Trasferimento tra reti · un flusso alla volta (niente pattern nel tempo) · solo livello di rete
Split casuale: numeri in-dominio ottimistici · stime affidabili solo sui DoS (Infiltration 7 casi, Heartbleed 1)

Un secondo livello non sostituisce il classificatore: recupera minacce specifiche che il classificatore manca, a un costo di falsi allarmi misurato.

Sviluppo futuro: affiancare un EDR (agente sull'host: processi, utenti, payload decifrato)

Grazie — domande? →